

Cybersecurity of network and information systems

SUMMARY OF:

[Directive \(EU\) 2022/2555 on measures for a high common level of cybersecurity across the EU](#)

WHAT IS THE AIM OF THE DIRECTIVE?

Directive (EU) 2022/2555, known as NIS2, sets out a common [cybersecurity](#) regulatory framework aiming to enhance the level of cybersecurity in the [European Union](#) (EU), requiring EU [Member States](#) to strengthen cybersecurity capabilities and introduce cybersecurity risk-management measures and reporting in critical sectors, along with rules on cooperation, information sharing, supervision and enforcement.

KEY POINTS

Cybersecurity refers to the activities necessary to protect network and information systems, the users of such systems and other people affected by cyber threats.

Critical sectors

The [directive](#) applies principally to medium-sized and large entities operating in the following **sectors of high criticality**, as defined in its Annex I:

- **energy:**
 - **electricity**, including production, distribution and transmission systems and recharging points,
 - **district heating and cooling**,
 - **oil**, including production, storage and transmission pipelines,
 - **gas**, including supply, distribution and transmission systems and storage, and

- **hydrogen**;
- **transport** by air, rail, water and road;
- **banking and financial market infrastructures**, such as credit institutions, operators of trading venues and central counterparties;
- **health**, including healthcare providers, manufacturers of basic pharmaceutical products and critical medical devices, and EU reference laboratories;
- **drinking water**;
- **waste water**;
- **digital infrastructure**, including providers of data centre services, cloud computing services, public electronic communications networks and publicly available electronic communications services;
- **ICT-managed services** (business-to-business);
- **space**;
- **public administration** at the central and regional levels, excluding the judiciary, parliaments and central banks; the directive does not apply to public administration entities that carry out activities in the areas of national security, public security, defence or law enforcement.

It also applies to **other critical sectors**, as defined in Annex II:

- **postal and courier services**;
- **waste management**;
- **chemical** manufacturing, production and distribution;
- **food** production, processing and distribution;
- **manufacturing**, specifically of medical devices, computer, electronic and optical products, certain types of electrical equipment and machinery, motor vehicles and other transport equipment;
- **digital providers** of online marketplaces, search engines and social networks; and
- **research organisations**.

National cybersecurity strategy

Every Member State must adopt a national strategy to achieve and maintain a high level of cybersecurity in the critical sectors, including:

- a governance framework clarifying the roles and responsibilities of relevant stakeholders at the national level;
- policies addressing the security of supply chains;

- policies on managing vulnerabilities;
- policies on promoting and developing education and training on cybersecurity; and
- measures to improve cybersecurity awareness among citizens.

Member States must **establish a list of essential and important entities**, along with entities providing domain name registration services, by **17 April 2025**. They must review and, where appropriate, update that list regularly, and at least every two years thereafter. The [European Commission](#) has adopted [guidelines](#) concerning the information that needs to be collected when drawing up these lists, along with a template for doing so.

The Commission has also issued [guidelines](#) clarifying the rules on the **relationship between Directive (EU) 2022/2555 and current and future sector-specific EU [legal acts](#)** addressing **cybersecurity risk-management measures** or **incident reporting requirements**. The appendix to the guidelines provides a non-exhaustive list of the sector-specific legal acts that the Commission considers as falling within the scope of Article 4 of Directive (EU) 2022/2555.

Computer security incident response teams

Computer security incident response teams (CSIRTs) provide technical assistance to entities, including:

- monitoring and analysing cyber threats, vulnerabilities and incidents at the national level;
- providing early warnings, alerts, announcements and information to the entities concerned and to other stakeholders on cyber threats, vulnerabilities and incidents, if possible in near real time;
- responding to incidents and providing assistance where applicable;
- collecting and analysing forensic data and providing dynamic risk and incident analysis and situational awareness on cybersecurity; and
- providing, on request, proactive network and information system scanning to detect vulnerabilities with a potentially significant impact.

CSIRTs network

The directive sets up a network of national CSIRTs to promote swift and effective operational cooperation.

Coordinated vulnerability disclosure

Member States must:

- designate one of their CSIRTs to coordinate the disclosure of vulnerabilities discovered in ICT products or services; and
- ensure that people in the Member States are able to report vulnerabilities, anonymously if requested.

The [European Union Agency for Cybersecurity](#) (ENISA) will develop and maintain a [vulnerability database](#).

Cooperation group

The directive sets up a cooperation group to support and facilitate strategic cooperation and information exchange. It is composed of representatives of Member States, the Commission and ENISA. Where appropriate, the cooperation group may invite the [European Parliament](#) and representatives of relevant stakeholders to participate in its work.

[European Cyber Crises Liaison Organisation Network](#)

The European Cyber Crises Liaison Organisation Network (EU-CyCLONe) comprises representatives of Member States' cyber crisis management authorities, along with the Commission in cases where a potential or ongoing large-scale cybersecurity incident has or is likely to have a significant impact on the sectors covered by the directive. In other cases, the Commission will participate in the activities of the network as an observer.

The network supports the coordinated management of large-scale cybersecurity incidents and crises at the operational level and ensures the regular exchange of information among Member States and [EU institutions](#), bodies, offices and [agencies](#).

The network is tasked, among other things, with:

- coordinating the management of large-scale cybersecurity incidents and crises and supporting decision-making at the political level;
- increasing preparedness;
- developing a shared situational awareness; and
- assessing the consequences and impact of large-scale cybersecurity incidents and crises and proposing possible mitigation measures.

Cybersecurity risk-management measures

Entities must take appropriate and proportionate technical, operational and organisational cybersecurity risk-management measures. The catalogue of measures

includes, among other things, risk analysis and information system security policies, incident handling, business continuity, disaster recovery and crisis management, supply chain security, vulnerability handling and disclosure, basic hygiene practices, policies and procedures regarding the use of cryptography (and encryption, where appropriate), human resource security and the use of multi-factor authentication or continuous authentication solutions. These measures have to be based on an all-hazards approach.

Management bodies must approve these measures and oversee their implementation and can be held liable for infringements.

Reporting

Entities must notify their CSIRT or relevant authority of any incident that:

- has cause or is capable of causing severe operational disruption or financial loss for the entity;
- has affected or could affect others by causing considerable material or non-material damage.

Furthermore, ENISA will produce, together with the Commission and the cooperation group, a biennial report on the state of cybersecurity in the EU, which will also be submitted to the Parliament.

Supervision and enforcement

The directive provides for remedies and sanctions to ensure enforcement.

Peer reviews

Peer reviews are set up with a view to learning from shared experiences, strengthening mutual trust, achieving a high common level of cybersecurity and enhancing Member States' cybersecurity capabilities and policies necessary for implementing this directive. These reviews entail on-site or virtual visits and off-site exchanges of information. Participation in these peer reviews is voluntary.

Implementing act

Implementing Regulation (EU) [2024/2690](#) lays down rules for applying Directive (EU) 2022/2555 as regards **technical and methodological requirements** of cybersecurity **risk-management measures** and further specifies the **cases in which an incident is considered to be significant** with regard to:

- domain name system service providers,
- top-level domain name registries,
- cloud computing service providers,
- data centre service providers,
- content delivery network providers,
- managed service providers,
- managed security service providers,
- providers of online marketplaces, of online search engines and of social networking services platforms, and
- trust service providers.

Repeal

Directive (EU) 2022/2555 repealed Directive (EU) [2016/1148](#) (see [summary](#)) from 18 October 2024, and Implementing Regulation (EU) 2024/2690 repealed Implementing Regulation (EU) 2018/151, which laid down rules for applying Directive (EU) 2016/1148.

FROM WHEN DO THE RULES APPLY?

The directive had to be [transposed](#) into national law by 17 October 2024. The rules have applied since 18 October 2024.

BACKGROUND

For further information, see:

- [Cybersecurity](#) (European Commission)
- [How the EU is strengthening its cybersecurity](#) (European Council, Council of the European Union)
- [How the EU responds to crises and builds resilience](#) (European Council, Council of the European Union)
- [A digital future for Europe](#) (European Council, Council of the European Union).

MAIN DOCUMENT

Directive (EU) [2022/2555](#) of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the

Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive) (OJ L 333, 27.12.2022, pp. 80–152).

Successive amendments to Directive (EU) 2022/2555 have been incorporated into the original version. This [consolidated version](#) is of documentary value only.

RELATED DOCUMENTS

Commission Implementing Regulation (EU) [2024/2690](#) of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures and further specification of the cases in which an incident is considered to be significant with regard to DNS service providers, TLD name registries, cloud computing service providers, data centre service providers, content delivery network providers, managed service providers, managed security service providers, providers of online market places, of online search engines and of social networking services platforms, and trust service providers (OJ L, 2024/2690, 18.10.2024).

[Communication](#) from the Commission – Commission Guidelines on the application of Article 3(4) of Directive (EU) 2022/2555 (NIS 2 Directive) 2023/C 324/02 (OJ C 324, 14.9.2023, pp. 2–7).

[Communication](#) from the Commission – Commission Guidelines on the application of Article 4(1) and (2) of Directive (EU) 2022/2555 (NIS 2 Directive) 2023/C 328/02 (OJ C 328, 18.9.2023, pp. 2–10).

Regulation (EU) [2022/2554](#) of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (OJ L 333, 27.12.2022, pp. 1–79).

Directive (EU) [2022/2557](#) of the European Parliament and of the Council of 14 December 2022 on the resilience of critical entities and repealing Council Directive 2008/114/EC (OJ L 333, 27.12.2022, pp. 164–198).

Regulation (EU) [2021/696](#) of the European Parliament and of the Council of 28 April 2021 establishing the Union Space Programme and the European Union Agency for the Space Programme and repealing Regulations (EU) No 912/2010, (EU) No 1285/2013 and (EU) No 377/2014 and Decision No 541/2014/EU (OJ L 170, 12.5.2021, pp. 69–148).

Regulation (EU) [2021/694](#) of the European Parliament and of the Council of 29 April 2021 establishing the Digital Europe Programme and repealing Decision (EU) 2015/2240 (OJ L 166, 11.5.2021, pp. 1–34).

See [consolidated version](#).

Regulation (EU) [2019/881](#) of the European Parliament and of the Council of 17 April 2019 on ENISA (the European Union Agency for Cybersecurity) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act) (OJ L 151, 7.6.2019, pp. 15–69).

See [consolidated version](#).

Commission Recommendation (EU) [2019/534](#) of 26 March 2019 – Cybersecurity of 5G networks (OJ L 88, 29.3.2019, pp. 42–47).

Regulation (EU) [2018/1139](#) of the European Parliament and of the Council of 4 July 2018 on common rules in the field of civil aviation and establishing a European Union Aviation Safety Agency, and amending Regulations (EC) No 2111/2005, (EC) No 1008/2008, (EU) No 996/2010, (EU) No 376/2014 and Directives 2014/30/EU and 2014/53/EU of the European Parliament and of the Council, and repealing Regulations (EC) No 552/2004 and (EC) No 216/2008 of the European Parliament and of the Council and Council Regulation (EEC) No 3922/91 (OJ L 212, 22.8.2018, pp. 1–122).

See [consolidated version](#).

Directive (EU) [2018/1972](#) of the European Parliament and of the Council of 11 December 2018 establishing the European Electronic Communications Code (Recast) (OJ L 321, 17.12.2018, pp. 36–214).

See [consolidated version](#).

Council Implementing Decision (EU) [2018/1993](#) of 11 December 2018 on the EU Integrated Political Crisis Response Arrangements (OJ L 320, 17.12.2018, pp. 28–34).

Commission Recommendation (EU) [2017/1584](#) of 13 September 2017 on coordinated response to large-scale cybersecurity incidents and crises (OJ L 239, 19.9.2017, pp. 36–58).

Regulation (EU) [2016/679](#) of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, pp. 1–88).

See [consolidated version](#).

Regulation (EU) No [910/2014](#) of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC (OJ L 257, 28.8.2014, pp. 73–114).

See [consolidated version](#).

Directive [2013/40/EU](#) of the European Parliament and of the Council of 12 August 2013 on attacks against information systems and replacing Council Framework Decision

2005/222/JHA (OJ L 218, 14.8.2013, pp. 8–14).

Decision No [1313/2013/EU](#) of the European Parliament and of the Council of 17 December 2013 on a Union Civil Protection Mechanism (OJ L 347, 20.12.2013, pp. 924–947).

See [consolidated version](#).

Directive [2011/93/EU](#) of the European Parliament and of the Council of 13 December 2011 on combating the sexual abuse and sexual exploitation of children and child pornography, and replacing Council Framework Decision 2004/68/JHA (OJ L 335, 17.12.2011, pp. 1–14).

See [consolidated version](#).

Regulation (EC) No [300/2008](#) of the European Parliament and of the Council of 11 March 2008 on common rules in the field of civil aviation security and repealing Regulation (EC) No 2320/2002 (OJ L 97, 9.4.2008, pp. 72–84).

See [consolidated version](#).

Directive [2002/58/EC](#) of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications) (OJ L 201, 31.7.2002, pp. 37–47).

See [consolidated version](#).

last update 7.3.2025

[nach oben](#)